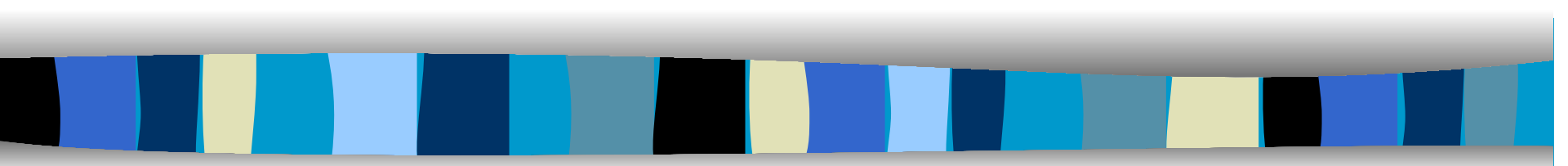


Malicious Logic



Virus, Worm, Trojan, Zombies,
Intrusion Detection

Malicious Logic

- Malicious Logic is set of instructions that is intentionally developed to attack systems or violate the security policy.
- It is also known as malware.
- Most of malware are delivered through internet (email or website).
- Malware might need a host program to execute or can be independent.
- Malware can replicate themselves while some of malware does not replicate.

Types of Malware

- Major Types of Malware are
- Computer virus
- Trojan Horse
- Worm
- Zoombies

Computer Virus

- Virus is self-replicating software that attaches itself to other software.
- It operates when infected code executes.
- It alters the normal code.
- Tries to remain undetected.
- Virus requires some form of user interaction to the user's device.

Computer Virus

- The classic example is an e-mail attachment containing malicious executable code.
- If a user receives and opens such an attachment, the user inadvertently runs the malware on the device.
- Once executed, the virus may send an identical message with an identical malicious attachment to, for example, every recipient in the user's address book.

Trojan Horse

- A computer program that appears to have a useful function, but also has a hidden and potentially malicious function that evades security mechanisms.
- It can exploit legitimate authorizations of a system entity that invokes the Trojan horse program.
- It can act as server accepting and executing commands for remote administrator.
- This includes intercepting keystrokes and mouse motions and sending them to attacker – Also allows attacker to upload, download files

Trojan Horse

- It masquerade as legitimate file or helpful program.
- Some Trojan Horse can make copies of itself resembling to computer virus.

Worm

- Worms are malware that can enter a device without any explicit user interaction.
- Without any user intervention, the vulnerable network application may accept the malware from the Internet and run it, creating a worm.
- The worm in the newly infected device then scans the Internet, searching for other hosts running the same vulnerable network application.
- When it finds other vulnerable hosts, it sends a copy of itself to those hosts.
- Today, malware, is pervasive and costly to defend against.

Zombie

- A program which secretly takes over another networked computer.
- Then Zombie uses it to indirectly launch attacks.
- Often Zombie launches Distributed Denial of Service attack.
- Exploits known flaws in network systems.

Distributed Denial of Service

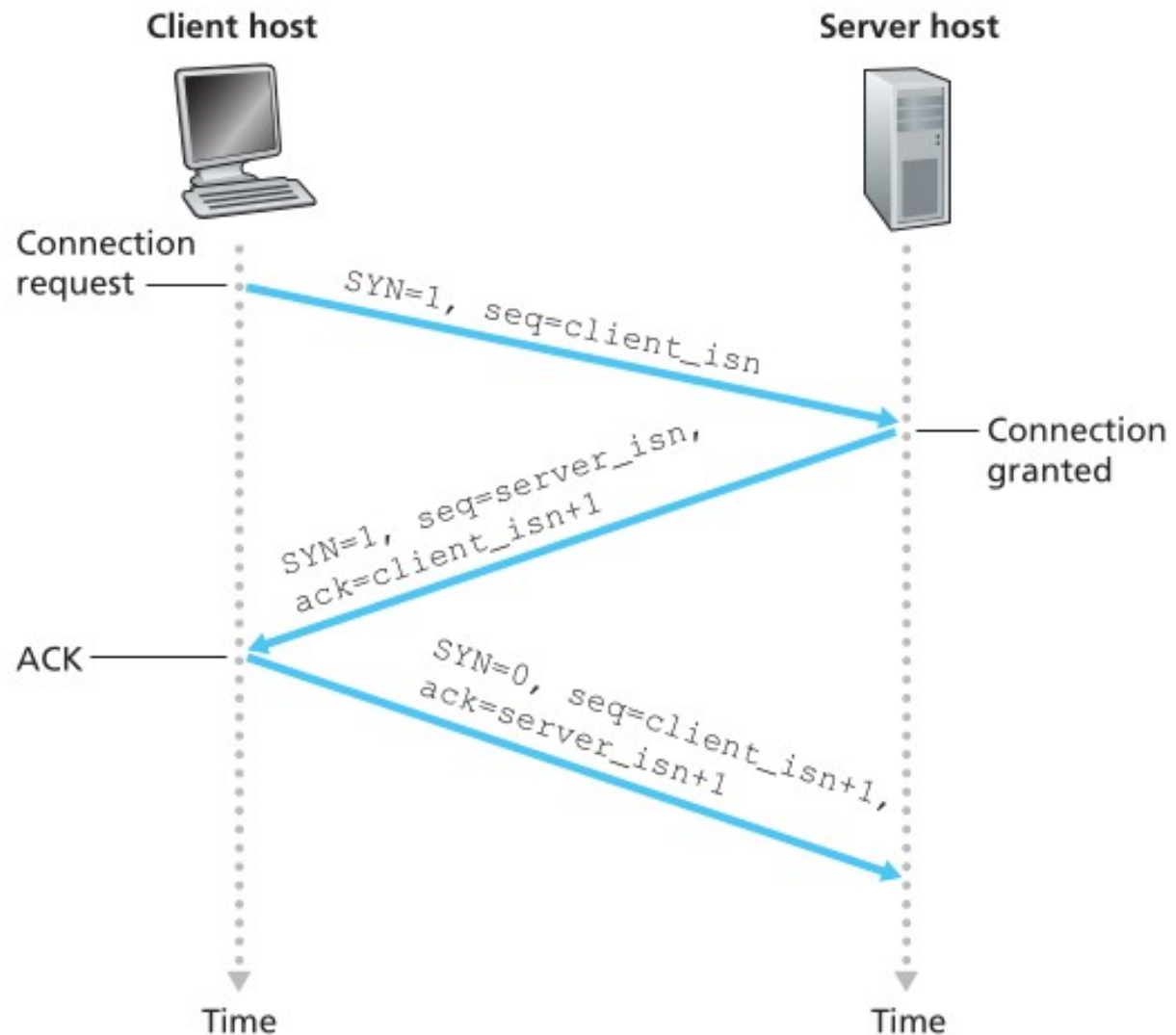
- A denial of service (DoS) attack is an attempt to prevent legitimate users of a service from using that service.
- In DoS, the attack comes from a single host.
- In a Distributed DoS attack, attackers use different hosts to attack the target simultaneously.
- A DDoS attacker attempts to consume the target's resources so that it cannot provide service.
- The attack can consume the internal resource and transmission capacity in the local network.

Distributed Denial of Service

- One of the Distributed Denial of Service is **SYN flooding**.
- It is related to TCP connection.
- So, before we study SYN Flooding, we will get some background of TCP connection.

Distributed Denial of Service

- **TCP Connection**



Distributed Denial of Service

- **TCP Connection** proceeds with following three way handshake
- **Step 1:** client sends a TCP segment setting SYN field to 1, seq # field with randomly generated number to server.
- SYN=1 notifies that client want to connect with server.
- Seq # is used for security purpose.

Distributed Denial of Service

- **TCP Connection** proceeds with following three way handshake
- **Step 2:** Server upon receiving SYN segment, server allocates buffers and variables for connection.
- Then server sends a TCP segment setting SYN field to 1, seq # field with randomly generated number and ACK = seq # of client +1 to the client.
- The segment with SYN=1 and ACK!=0 is called SYNACK.
- ACK=seq # of client +1 specifies the next segment is requested.

Distributed Denial of Service

- **TCP Connection** proceeds with following three way handshake
- **Step 3:** After receiving SYNACK segment, client also allocates buffers and variables for the connection.
- Then, client sends a TCP segment setting SYN=0, seq # = seq # of client +1 and ACK =seq # of server +1
- The segment with SYN=0 and ACK!=0 is called acknowledgment segment .
- Now, client and server can send application layer data.

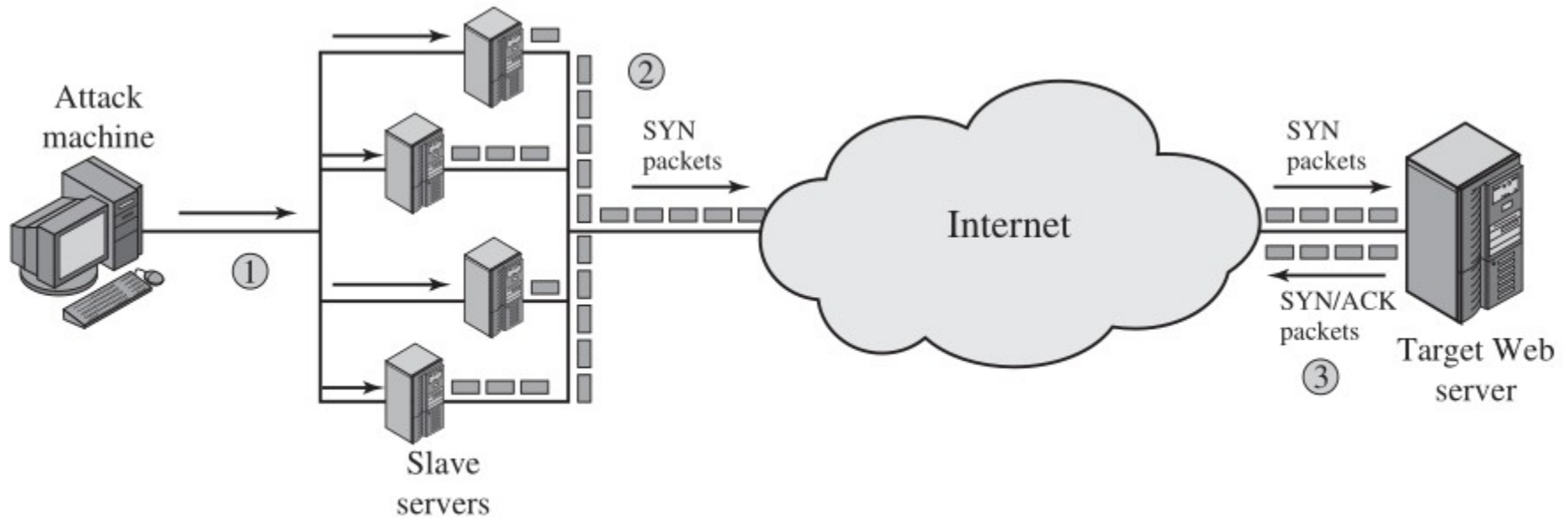
Distributed Denial of Service

- **With this knowledge attacker can perform DDoS attack as follows**
- 1. The attacker takes control of multiple hosts over the Internet, instructing them to launch the attack on the target.
- 2. The slave hosts begin sending TCP/IP SYN packets, with erroneous return IP address information, to the target.
- 3. Each SYN packet is a request to open a TCP connection.

Distributed Denial of Service

- For each such packet, the Web server responds with a SYN/ACK (synchronize/acknowledge) packet, trying to establish a TCP connection with a TCP entity at a spurious IP address.
- The Web server maintains a data structure for each SYN request waiting for a response back and becomes bogged down as more traffic floods in.
- The result is that legitimate connections are denied while the victim machine is waiting to complete bogus “half-open” connections.

Distributed Denial of Service



(a) Distributed SYN flood attack

Intrusion Detection System

- We've just seen that a packet filter inspects IP, TCP, UDP, and ICMP header fields when deciding which packets to let pass through the firewall.
- However, to detect many attack types, we need to perform deep packet inspection, that is, look beyond the header fields and into the actual application data that the packets carry.

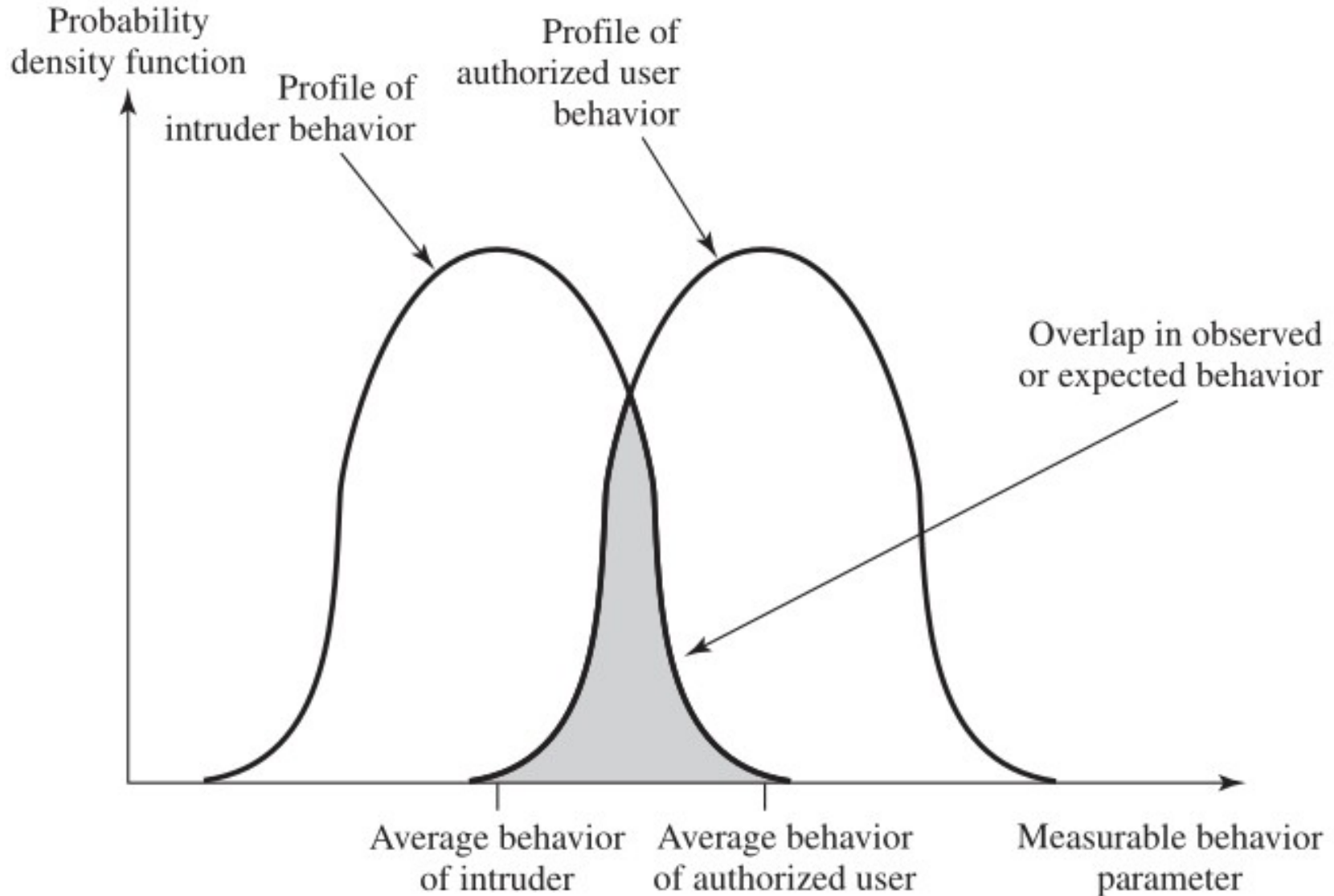
Intrusion Detection System

- We need such a device that can prevent those packets suspicious packets from entering the organizational network.
- Some devices could let the packets pass, but send alerts to a network administrator, who can then take a closer look at the traffic and take appropriate actions.
- A device that generates alerts when it observes potentially malicious traffic is called **an intrusion detection system (IDS)**.

Intrusion Detection System

- A device that filters out suspicious traffic is called an **intrusion prevention system (IPS)**.
- Inevitably, the best intrusion prevention system will fail.
- So, we are interested in intrusion detection system.
- Intrusion detection is based on the assumption that the behavior of the intruder differs from that of a legitimate user in ways that can be quantified.
- Note that, there will be some overlap.

Intrusion Detection System



Intrusion Detection System

- Thus, a loose interpretation of intruder behavior, which will catch more intruders, will also lead to a number of “false positives,” or authorized users identified as intruders.
- On the other hand, an attempt to limit false positives by a tight interpretation of intruder behavior will lead to an increase in false negatives, or intruders not identified as intruders.
- Thus, there is an element of compromise and art in the practice of intrusion detection.

IDS: Audit records

- **Audit records** refers to the ongoing activities of the users.
- We can detect abnormal behaviour by comparing audit records.
- So, audit records must be maintained for intrusion detection system.
- Audit records can be **Native audit records** and **Detection specific audit records**.
- Native audit records can be gathered using accounting packages.

IDS: Audit records

- Native audit records may not contain the needed information for intrusion detection.
- Some specific system can be implemented to gather the detection specific audit records.
- These system gathers information required for intrusion detection system only.

Intrusion Detection System

- **Advantages:**
- 1. If an intrusion is detected quickly enough, the intruder can be identified and ejected from the system before any damage is done.
- 2. Even if the detection is not timely, amount of damage can be less and recovery can be achieved quickly.
- 3. Intrusion detection enables the collection of information about intrusion techniques that can be used to strengthen the intrusion prevention facility.

Intrusion Detection System

- **Mainly two types**
- Statistical Detection
- Rule Based Detection

Statistical Intrusion Detection

- Statistical anomaly detection Involves the collection of data relating to the behavior of legitimate users over a period of time.
- Then statistical tests are applied to observed behavior to determine with a high level of confidence whether that behavior is not legitimate user behavior.
- **Threshold detection:**
- **Profile Detection**

Statistical Intrusion Detection

- **Threshold detection:** This approach involves defining thresholds for occurrence of various events.
- Then it counts the number of occurrences of a specific event type over an interval of time.
- If the count surpasses the threshold then one might expect to occur intrusion.
- Threshold depends upon the user.
- So, this approach is likely to generate either a lot of false positives or a lot of false negatives.

Statistical Intrusion Detection

- **Profile based:** A profile of the activity of each user is developed and used to detect changes in the behavior of individual accounts.
- A profile may consist of a set of parameters, so that deviation on just a single parameter may not be sufficient in itself to signal an alert.
- The foundation of this approach is an analysis of audit records.
- The audit records provide input to the intrusion detection function in two ways.

Statistical Intrusion Detection

- First, the designer must decide on a number of quantitative metrics that can be used to measure user behavior.
- An analysis of audit records over a period of time can be used to measure the activity profile of the average user.
- Thus, the audit records serve to define typical behavior.
- Second, current audit records are the input used to detect intrusion.

Statistical Intrusion Detection

- That is, the intrusion detection model analyzes incoming audit records to determine deviation from average behavior.
- Metric used for profile based intrusion detection systems are
- **Counter**: Non-negative integer that counts certain events.
- For e.g. number of password failure.
- **Gauge**: A non-negative integer that measures the current value of some entity.

Statistical Intrusion Detection

- For e.g., number of outgoing messages queued for a user process.
- **Interval timer:** The length of time between two related events.
- For e.g. the length of time between successive logins to an account.
- **Resource utilization:** Quantity of resources consumed during a specified period.
- For e.g. total time consumed by a program execution.

Statistical Intrusion Detection

- Based upon various metric, statistical test can be done.
- The simplest statistical test is to measure the **mean and standard deviation** of a parameter over some historical period.
- This gives a reflection of the average behavior and its variability.
- The use of mean and standard deviation is applicable to a wide variety of **counters, timers, and resource measures**.

Rule Based Intrusion Detection

- Rule-based detection Involves an attempt to define a set of rules that can be used to decide that a given behavior is that of an intruder.
- **Anomaly detection:**
- **Penetration identification:**

Rule Based Intrusion Detection

- **Anomaly detection:** Rules are developed to detect deviation from previous usage patterns.
- It is similar in terms of its approach and strengths to statistical anomaly detection.
- With the rule-based approach, historical audit records are analyzed to identify usage patterns and to generate automatically rules that describe those patterns.
- Rules may represent past behavior patterns of users, programs, privileges, time slots, terminals, and so on.

Rule Based Intrusion Detection

- **Anomaly detection:** Current behavior is then observed, and each transaction is matched against the set of rules to determine if it conforms to any historically observed pattern of behavior.

Rule Based Intrusion Detection

- **Penetration identification:** A rule based expert system approach that searches for suspicious behavior.
- It takes a very different approach to intrusion detection.
- The key feature of such systems is the use of rules for identifying known penetrations or penetrations that would exploit known weaknesses.

Rule Based Intrusion Detection

- **Penetration identification:**
- Rules can also be defined that identify suspicious behavior, even when the behavior is within the bounds of established patterns of usage.
- Typically, the rules used in these systems are specific to the machine and operating system.